

PRODUCT REQUIREMENTS DOCUMENT

(PRD)

AI-Powered Incident Response Orchestration System

Problem Statement 22
Category: Cybersecurity / AI / SecOps
Product Type: Incident Management Platform

1.0 PRODUCT OVERVIEW

The **AI-Powered Incident Response Orchestration System** is an intelligent cybersecurity platform designed to automate and coordinate post-incident response activities across multiple security tools and operational teams. When a cybersecurity incident such as malware detection, phishing, ransomware, or unauthorized access occurs, security teams must perform time-sensitive activities including alert validation, threat investigation, containment, remediation, recovery, and documentation.

The system uses AI-assisted analysis, rule-based automation, and integrated security tools to coordinate these activities through predefined incident response playbooks. It provides a centralized interface for monitoring incidents, tracking response progress, executing approved actions, managing human approvals, and maintaining a complete audit trail. The primary objective is to reduce incident response delays, minimize manual intervention, improve response consistency, and provide operational visibility while retaining human control over critical security decisions.

2.0 PROBLEM STATEMENT

Organizations face increasing cybersecurity threats, but their incident response processes remain fragmented across multiple security platforms, communication channels, and teams. Security analysts must manually investigate alerts, identify affected systems, execute containment procedures, coordinate with IT teams, and update incident records. Key challenges include:

- **Delayed Incident Containment:** Manual coordination increases response window and potential damage.
- **Lack of Tool Integration:** Siloed operation between SIEM, EDR, Firewall, IAM, and Ticketing platforms.
- **Inconsistent Execution:** Varied execution of incident response procedures depending on analyst experience.
- **Human Error & Omission:** Missed remediation steps during high-stress operational moments.
- **Limited Real-Time Visibility:** Lack of centralized tracking for ongoing multi-step response activities.
- **Incomplete Incident Documentation:** Difficulty maintaining chronological logs for audits and compliance.
- **Increased Workload:** Heavy cognitive load and fatigue for SOC teams dealing with repetitive manual tasks.

Core Problem: The absence of a centralized, intelligent orchestration mechanism that can coordinate incident response workflows efficiently, consistently, and securely.

3.0 PRODUCT VISION & CORE OBJECTIVES

PRODUCT VISION

To develop an intelligent, centralized cybersecurity response platform that transforms fragmented incident handling into a coordinated, transparent, and approval-driven automated workflow—assisting security teams from alert detection to investigation, containment, remediation, recovery, and closure through a unified interface.

Product Objectives (1 - 4)

- Automate repetitive response activities using predefined playbooks.
- Analyze incident context for AI-assisted recommendations.
- Coordinate security tools via central orchestration.
- Reduce time between detection, validation, and containment.

Product Objectives (5 - 8)

- Provide real-time incident status and execution visibility.
- Maintain detailed logs of every action performed.
- Ensure human approval for critical operations.
- Improve response consistency and reduce operational errors.

4.0 TARGET USERS & STAKEHOLDER ROLES

USER ROLE	PRIMARY RESPONSIBILITIES	KEY SYSTEM INTERACTIVITY
SOC Analyst	Monitors alerts, investigates incidents, and initiates response workflows.	Triggers playbooks, views AI summaries, submits approval requests.
Incident Response Manager	Reviews critical incidents and approves sensitive response actions.	Approves/Rejects high-impact tasks, oversees response timelines.
Security Administrator	Configures tool integrations, security policies, and playbook rules.	Manages API adapters, secrets, playbook definitions, user roles.
IT Operations Team	Handles system recovery, host patching, and infrastructure remediation.	Receives task assignments, marks recovery milestones completed.
Organization Administrator	Manages system-wide users, permissions, and organization settings.	User provisioning, system audit log oversight, RBAC policies.

5.0 PROPOSED SOLUTION & ARCHITECTURAL SEPARATION

The platform introduces an AI-assisted orchestration agent that acts as a central coordinator between security alerts, incident response playbooks, security tools, and response teams. The core architecture strictly separates responsibilities into three distinct pillars:

1. AI Agent REASONING Analyzes raw incident context, interprets security alerts, synthesizes logs, and suggests playbooks. <i>Has zero direct execution rights.</i>	2. Orchestration Engine EXECUTION Controls task sequencing, evaluates policy rules, enforces state persistence, and dispatches API requests to tool adapters.	3. Human Analyst GOVERNANCE Validates threat severity, reviews high-risk action descriptions, and retains ultimate authorization over disruptive operations.
--	--	---

6.0 CORE PRODUCT MODULES (PART 1: 6.1 - 6.5)

6.1 Security Incident Dashboard

Centralized overview displaying: Total incidents detected; Active, investigating, contained, and resolved counts; Severity-wise distribution; Real-time incident timeline; Affected asset information; Response progress indicators; Recent security alerts feed; Pending human approval requests banner.

6.2 Alert Ingestion & Incident Classification

Receives security alerts via REST API / webhooks. Features alert deduplication, incident categorization, severity classification, affected asset identification, and alert-to-incident mapping. *Supported Categories: Malware detection, Phishing, Suspicious login, Unauthorized access, Ransomware alerts.*

6.3 AI Incident Analysis Agent

Analyzes structured incident data to produce contextual understandings. Responsibilities: Summarize incident details, identify affected assets, interpret security alerts, suggest playbooks, explain recommended actions, identify missing data, and recommend escalation when uncertainty is high.

6.4 Playbook Engine

Coordinates predefined response procedures containing trigger conditions, investigation steps, containment actions, remediation, recovery, approvals, and failure handling.

6.5 Response Execution

Executes authorized actions via EDR, Firewall, SIEM, Patch, and Ticketing APIs. Tracks status: Pending, Approved, Running, Completed, Failed, Escalated.

6.0 CORE PRODUCT MODULES (PART 2: 6.6 - 6.8)

6.6 Human Approval & Oversight

Dedicated approval mechanism ensuring critical decisions remain under human control. Features approval queues, risk impact descriptions, approve/reject options, approval history, escalation, and emergency workflow pause.

6.7 Incident Ticketing & Comms

Centralized documentation and team coordination. Features automatic ticket creation, status sync, team assignments, action history logs, incident comments, escalation notifications, and resolution summaries.

6.8 Audit & Reporting Module

Maintains a chronological record of the full lifecycle. Features activity timelines, action execution logs, user approval records, failed action reports, response time metrics, and exportable PDF post-mortem reports.

7.0 FUNCTIONAL REQUIREMENTS (FR-01 TO FR-15)

ID	REQUIREMENT DESCRIPTION	MODULE	PRIORITY
FR-01	User authentication and Role-Based Access Control (RBAC)	Security	HIGH
FR-02	Centralized security incident dashboard with real-time metrics	Dashboard	HIGH
FR-03	Security alert ingestion interface via REST API / Webhooks	Ingestion	HIGH
FR-04	Automatic incident classification and severity assignment	Ingestion	HIGH
FR-05	AI-assisted incident summarization and telemetry interpretation	AI Agent	HIGH
FR-06	Contextual playbook selection based on incident indicators	Playbook	HIGH
FR-07	Step-by-step workflow orchestration and state tracking	Orchestration	HIGH
FR-08	Human approval gate for critical / disruptive operations	Approval	HIGH
FR-09	Real-time incident execution status tracking and timeline display	Dashboard	HIGH
FR-10	Detailed action execution history logging and audit trails	Audit	HIGH
FR-11	Centralized incident ticket creation and status management	Ticketing	MEDIUM
FR-12	Execution failure detection, automatic retry, and escalation handling	Orchestration	HIGH
FR-13	Response metric calculation (MTTD, MTTC, MTTR) & reporting	Reporting	MEDIUM
FR-14	External security tool integration adapters (EDR, Firewall, SIEM)	Integrations	MEDIUM
FR-15	Custom playbook configuration interface for administrators	Playbook	MEDIUM

8.0 NON-FUNCTIONAL REQUIREMENTS

Security & Auditability

- **Security:** RBAC, encrypted secret storage, TLS 1.3 communication, JWT authentication, least-privilege permissions.
- **Auditability:** Timestamped action logs, non-repudiable user approvals, traceable execution history.

Reliability, Performance & Scalability

- **Reliability:** Persistent state recovery, retry mechanisms for transient failures, idempotency checks.
- **Performance:** Responsive dashboard (<1s), fast alert processing, real-time websocket updates.
- **Scalability:** Concurrent incident handling, modular API connectors, extensible playbook engine.

9.0 END-TO-END INCIDENT RESPONSE LIFECYCLE WORKFLOW

The system executes response procedures following a structured 10-step lifecycle:



10.0 SYSTEM ARCHITECTURE & COMPONENT RESPONSIBILITIES

LAYER	COMPONENTS	CORE RESPONSIBILITIES
Presentation Layer	React.js / Tailwind CSS / Recharts	Dashboard UI, incident details, approval modals, timelines.
API Layer	Python FastAPI	Authentication, REST APIs, RBAC middleware, service routing.
Intelligence Layer	LLM API (OpenAI / Gemini)	Incident log parsing, contextual summaries, playbook suggestions.
Orchestration Layer	LangGraph / State Engine	Playbook sequencing, approval enforcement, state checkpoints.
Integration Layer	API Connectors / Adapters	Communication with EDR, Firewall, SIEM, and Ticketing systems.
Data Layer	PostgreSQL / Redis	Persistent store for incidents, playbooks, logs, and queue tasks.
Security Layer	JWT, RBAC, Secret Manager	Access token validation, role enforcement, encrypted API keys.

11.0 PROPOSED TECHNOLOGY STACK

Frontend & UI • React.js: Component UI • Tailwind CSS: Layout • Recharts: Analytics • Axios: API Client	Backend & AI • FastAPI: Async Web API • LangGraph: Workflow • LLM API: Gemini / OpenAI • JWT: Auth Token	Data & Infra • PostgreSQL: Relational DB • Redis: Task Queue • Docker: Containerization • GitHub: Version Control
--	---	--

12.0 MINIMUM VIABLE PRODUCT (MVP) SCOPE

The initial implementation focuses on demonstrating one complete, end-to-end incident response lifecycle for a Malware Detection Scenario using simulated tool adapters to demonstrate orchestration safely.

MVP USE CASE: MALWARE DETECTION & RESPONSE

Scenario: A simulated malware alert is generated on workstation FINANCE-PC-102.

Workflow Steps: Malware Alert Ingestion → Incident Creation → AI Summary Generation → Malware Playbook Selection → Display Execution Plan → Request Approval → Execute Simulated Endpoint Isolation → Execute Cleanup → Verify Results → Update Status → Export Final Post-Mortem PDF.

13.0 RISKS & MITIGATION STRATEGIES

IDENTIFIED RISK	MITIGATION STRATEGY
Incorrect AI Recommendations	Enforce strict schema validation and deterministic playbook policy rules. AI cannot override playbooks.
Unauthorized Action Execution	Role-based access controls (RBAC) and mandatory human approval gates for high-impact actions.
Tool API Failure During Execution	Automatic retry logic, error handling, and manual analyst escalation triggers.
False-Positive Alert Flooding	Analyst validation gates and confidence score thresholds before triggering playbooks.
Secret & Credential Exposure	Centralized, encrypted secret management (environment variables / key vault).
Operational Business Disruption	Mandatory human approval required for host isolation, firewall blocks, or account resets.
Incomplete Audit Trail	Centralized, immutable database logging triggered automatically on every system event.

14.0 SUCCESS METRICS & EXPECTED OUTCOMES

Key Performance Indicators (KPIs)

- **MTTD & MTTR:** Reduction in total detection and response duration.
- **Time to Containment:** Rapid containment post-approval (<3 mins).
- **Playbook Completion Rate:** High execution reliability (>98%).
- **Failed Action Rate:** Minimizing adapter execution errors.
- **Approval Response Time:** Tracking manager review speed.
- **Audit Completeness:** 100% decision and log coverage.

Expected Operational Outcomes

- Reduced manual coordination friction during critical incidents.
- Standardized execution of security response procedures.
- Unified real-time visibility into incident lifecycle progress.
- Eliminated false-positive auto-isolation risks via approvals.
- Decreased cognitive workload and fatigue for SOC analysts.
- Complete, audit-ready post-incident documentation.

15.0 PRODUCT SCOPE BOUNDARIES

In Scope

Incident management, AI analysis, playbook orchestration, controlled execution, human approvals, ticketing updates, audit logging, and response analytics.

Out of Scope (Initial Version)

Autonomous destructive operations, unrestricted AI CLI execution, automatic wiping of affected hosts, enterprise SIEM replacement, guaranteed breach prevention.